

# Security Auditing & Digital Forensics — Master Cheatsheet

University of Coimbra (MSI/MEI) 2025/2026 — compiled from **resumos** + slides T1–T10. **Blue**=compliance/audit, **Red**=forensics.

## 1. ISS Compliance, Assessment vs Audit (T1)

**Assessment** = internal health-check; improves; *non-attributive* (no blame); finds gaps.

**Audit** = *independent* pass/fail evaluation; consequences/penalties; auditors never audit their own work; about *past* performance.

**Risk-based mgmt (6 steps):** 1.Categorize system 2.Select baseline controls 3.Implement+document 4.Assess 5.Authorize (accept risk) 6.Monitor continuously.

**Audit types:** Financial, Compliance, Operational, Investigative, IT.

**Scope of audit:** Organizational / Compliance / Technical / Application.

**Risk Mgmt** mitigates via controls; **Compliance** verifies controls exist; **Governance** runs org with accurate info.

**Compliance steps:** interpret regulation → find gap → plan → execute.

**Policy** (mandatory, high-level) > **Standard** (mandatory specifics) > **Guideline** (recommended).

**Scope restrictions (bad):** too few resources, short timeframe, blocking evidence, restricting procedures, withholding history.

## 2. Planning an Audit + 7 Domains (T2)

**Plan** = Scope (area+period) / Goals (align objectives) / Objectives (int+ext reqs) / Frequency (1–3 yrs).

**7 Domains of IT infra:**

1. **User** – people; AUP, authentication.
2. **Workstation** – desktops/laptops/mobile; patching.
3. **LAN** – switches/file servers; hardening, backups.
4. **LAN-to-WAN** – routers/firewalls/IDS; public IPs, high security.
5. **WAN** – end-to-end links; untrusted zone.
6. **Remote Access** – VPN, 2FA, encryption.
7. **System/Application** – servers/apps; harden to baseline.

**Config Mgmt** = changes requested/evaluated/authorized.  
**Change Mgmt** = tracks unauthorized changes. **5 steps:** identify→evaluate→decide→implement→monitor.

**Threat sources:** Adversarial / Accidental / Structural / Environmental.

**Risk depends on:** likelihood × impact, minus control sufficiency. **Trade-offs:** cost, operational impact, feasibility.

**CAG** = SANS Top 20 Critical Security Controls.

## 3. ISO 27000 Family + ISMS (T3)

By ISO+IEC. **27001** = **ONLY** certifiable standard.

**Family:** 27001 (ISMS reqs) · 27002 (controls how-to) · 27003 (ISMS impl) · 27005 (risk) · 27007 (auditing) · 27017/27018 (cloud/PII) · 27019 (energy) · 27701 (privacy/PIMS) · 27035 (incidents).

**ISMS** = systematic mgmt of **CIA** (Confidentiality, Integrity, Availability) via **PDCA** (Plan-Do-Check-Act). 4 control kinds: organizational, people, physical, technological.

**Core components:** Leadership & commitment · Policies/procedures · Asset mgmt · Access control (PoLP, RBAC, MFA) · Risk mgmt · Incident response (IRP/DRP/BCP) · Continuous improvement.

**27001 vs 27002:** 27001=*what* (mgmt framework, Annex A objectives); 27002=*how* (detailed control guidance).

## 4. ISO 27002:2022 Controls + Risk (T4)

2022: 14 categories → **4 themes**; +5 attributes (Preventive, Detective, Corrective, Governance, Assurance).

**Themes:** **A.5 Organizational** (37) · **A.6 People** (8) · **A.7 Physical** (14) · **A.8 Technological** (34).

Notable: A.5.7 Threat intel · A.5.19–22 Supplier rel. · A.5.23 Cloud · A.5.28 Collection of evidence · A.8.15 Logging · A.8.16 Monitoring · A.8.17 Clock sync · A.8.24 Cryptography.

**SoA** (Statement of Applicability) = documents which controls chosen & why (from risk assessment).

**Risk treatment (4):** **Avoid** (remove exposure) · **Transfer** (insurance/outsource) · **Mitigate** (reduce likelihood/impact) · **Accept** (tolerate). (+Enhance for positive risks/opportunities.)

**Risk appetite** = amount of risk org will take for objectives.

## 5. ISO 27005 Risk Process (T4)

1. Context establishment (scope, criteria)
2. Risk identification (assets, threats, vulns, actors)
3. Risk analysis (likelihood × impact)
4. Risk evaluation (prioritize vs appetite)
5. Risk treatment (mitigate/avoid/transfer/accept)
6. Monitoring & review
7. Communication

Methods: Qualitative (L/M/H), Quantitative (€/%), Hybrid. Output: **RTP** (Risk Treatment Plan) mapped to Annex A.

## 6. Other ISO + Certification (T5)

**27017** Cloud security: shared-responsibility matrix.

- **IaaS:** customer controls app+platform; provider infra.
- **PaaS:** share app+platform; provider infra.
- **SaaS:** provider controls almost all; customer only data/usage.

**27018** PII in cloud (consent, encryption/anonymization, data residency, right to erasure).

**27019** Energy/OT & SCADA/ICS security.

**27701** PIMS for GDPR (controllers vs processors, PIA).

**27035** Incident mgmt 4 phases: Detect&Report → Assess&Classify → Respond&Contain → Recover&Learn.

**Certification:** Stage 1 (docs/readiness) → Stage 2 (on-site). Valid **3 yrs**; annual surveillance; recert @3yr.

**1st-party**=internal audit; **3rd-party**=accredited CB (BSI/TÜV/SGS).

## 7. NIST CSF 2.0 (T6)

Voluntary, risk-based. v2.0 (2024): 5 → **6 functions** (+Govern).

**G-I-P-D-R-R:**

- **Govern** – NEW; leadership, policy, accountability, supply-chain.
- **Identify** – assets, risk, supply chain.
- **Protect** – access (MFA/RBAC), encryption, training, patching.
- **Detect** – monitoring, anomalies, logging.
- **Respond** – IR, forensics, comms.
- **Recover** – DR, backups, lessons learned.

**Tiers (maturity):** 1 Partial · 2 Risk-Informed · 3 Repeatable · 4 Adaptive.

**Profiles:** Current → Target → gap analysis → action plan.

**Metrics:** MTTD (Detect), MTTR (Respond), Patch time (Protect), Phishing-click (Govern/Awareness), Compliance score.

Maps to ISO 27001, 800-53, CIS, Zero Trust.

## 8. NIS2 Directive (T7)

Why: NIS1 = narrow sectors, weak penalties, no supply-chain, no deadlines.

**NIS2 changes:** more sectors; **Essential** vs **Important** entities; mandatory supply-chain risk mgmt; MFA; mgmt **personally liable**.

**Reporting:** **24h early warning** → **72h full report** → 1-month final. To national CSIRT/competent authority.

**Penalties:** up to €10M or 2% global turnover; operational bans.  
**Art.21** core measures: risk mgmt, supply-chain, MFA, incident handling.  
Thresholds: EU-based/serving EU, >50 staff or >€10M turnover, or critical.

## 9. GDPR (T7)

1995 Directive → 2016 adopted → **25 May 2018** enforced.  
**Personal data** (Art.4(1)) = info on identifiable person. **Processing** (4(2)) = any operation.  
**Territorial (Art.3):** EU establishment OR offers goods/services to / monitors EU residents (extraterritorial).  
**6 legal bases (Art.6):** Consent · Contract · Legal obligation · Vital interests · Public task · Legitimate interests.  
**Principles:** lawfulness, fairness, transparency, purpose limitation, data minimization, accuracy, storage limitation, integrity&confidentiality, accountability.  
**Roles:** Data Subject · Controller (decides purpose) · Processor (acts for controller) · DPO.  
**8 rights:** informed, access, rectification, erasure (forgotten), restrict, portability, object, automated-decision (Art.12–22).  
**Breach:** notify authority ≤**72h** (Art.33); notify individuals if high risk (Art.34) – not needed if encrypted.  
**Fines:** Lower tier 2%/€10M (admin); Higher tier **4%/€20M** (rights/principles). EDPB + national DPAs.

## 10. DORA · EU Cyber Act · SOC2 (T7)

**DORA** = financial sector + ICT third parties. Cycle: Identify→Assess→Mitigate→Monitor. Incident: detect→internal→external (by next business day)→follow-up.  
**DORA Art.13** = post-incident review must include forensic analysis ("quality & speed of forensic analysis").  
**EU Cybersecurity Act (Reg 2019/881):** permanent **ENISA** mandate; EU certification schemes; 3 assurance levels **Basic/Substantial/High**; mutual recognition across EU.  
**SOC 2** (AICPA): **Type I**=design @point-in-time; **Type II** =operating effectiveness over 3–12 mo.  
**5 TSC: Security (mandatory)**, Availability, Processing Integrity, Confidentiality, Privacy.  
**Test methods:** Inquiry, Inspection, Observation, Re-performance.  
Opinion: unmodified / qualified / adverse.

## 11. Forensics Mindset & Legal Pillars (T8)

**Auditor** = controls exist/design. **Investigator** = reconstruct activity & intent.  
**Locard:** "every contact leaves a trace" (LNK, Shellbags, registry, USB logs, RAM strings, pagefile).  
**Court admissibility:** peer-reviewed tools (Autopsy/SleuthKit), known error rate, repeatable.  
**Chain of custody** = who collected/stored/accessed (gap = tampering window).  
**Hashing:** H(original)=H(image) ⇒ valid. **Dual hash** MD5+SHA-256 kills collisions. Original is "sacred": Source→Bitstream image→working copies.  
**Write-blocker** = allows reads, drops writes (HW > SW). Stops Windows writing timestamps/Thumbs.db.  
**Order of Volatility (RFC 3227):** Registers/Cache → RAM → Network state → Disk.  
**Live** acq = gets RAM/keys but alters system (min footprint); **Dead** box = powered-off, safest. Encryption (BitLocker) ⇒ must go live.  
**Logical copy** (files you see) vs **physical bit-stream** (dd, deleted/unallocated/hidden).  
**Magic bytes:** 4D5A=MZ exe · 25504446=%PDF · FFD8FF=JPEG.

## 12. Forensic Readiness (T8)

= maximize usable evidence, minimize cost. Starts at *design*, not after the hack.  
**5 Pillars:**  
1. **Time sync** (NTP, Stratum 1/2; sub-second; drift breaks timeline/court).  
2. **Advanced logging** (forensic-quality: Win 4688 process+cmdline, 4624 logon+IP, PowerShell ScriptBlock).  
3. **Legal mandate** (banners, contracts; GDPR/NIS2 right-to-monitor).  
4. **Triage tools** (Velociraptor/KAPE/EDR pre-deployed).  
5. **Trained first responders** (don't reboot/AV/admin-login; isolate but leave power ON).  
**Pipeline:** Monitoring(SIEM)→alerts→Forensics→root cause→IR→post-mortem→Audit.  
IR goal=continuity (wipe/restore) vs Forensics=preservation ⇒ **forensic-aware IR:** snapshots over wipes.  
**NIS2 Art.21** due care; **DORA Art.13** forensic analysis. No logs = "cyber-negligent".  
Reactive(ad-hoc)=costly/slow/low integrity; Proactive=cheap/fast/high integrity.

## 13. Endpoint/Memory Forensics + Vol3 (T9)

90% modern malware in RAM (fileless). RAM holds: plaintext passwords/keys, unsaved docs, hidden malware, recent CLI, clipboard, browser URLs.

**Artifacts:** physical RAM (.raw/.bin) · **hiberfil.sys** (compressed RAM on sleep) · **pagefile.sys** (virtual mem) · **.dmp** (crash).  
**Acquire SW:** Magnet RAM Capture, LiME (Linux LKM), AVML (Rust/cloud). **HW/DMA:** PCILeech, MemProcFS.  
**Speed: DMA < Network < SW**. DMA blocked by IOMMU/VT-d; can crash/BSOD.  
After acquire: **SHA-256 immediately**; record BIOS vs real time offset.  
**Volatility 3:** Python3 rewrite; **Profiles→Symbols** (PDB→ISF JSON, on-the-fly); **Automagic** auto-detects OS/layers. Syntax [OS].[plugin].  
**Plugins:** windows.info (1st; Is64Bit) · pslist (flat) · pstree (parent-child) · psscan (hidden/terminated) · netscan/netstat (sockets, C2 high ports) · dlllist/handles/modules (rootkits) · registry.printkey (Run key persistence) · **malfind** (RWX, unbacked, MZ header injection) · dumpfiles/memmap -dump (extract for Ghidra/IDA/VT).  
**VAD** (Virtual Address Descriptor) = AVL tree of process memory; detects hollowing.  
**MemProcFS** = mounts RAM as drive (M:\sys\proc\net\registry); use normal tools, instant timeline.

## 14. Scaling the Investigation (T10)

Crisis: 1000+ endpoints, hybrid cloud, encryption, ephemeral assets ⇒ "image everything" dead.  
**Dead-box fallacy:** high friction, huge storage (2TB=2TB), misses volatile data.  
**Triage:** grab golden artifacts <10 min. **KAPE** = Target (files to grab, raw disk access keeps timestamps) + Module (tool to parse → CSV/JSON). Flow: Identify→Extract→Process.  
**Golden artifacts:** **\$MFT** (NTFS master file table, file timeline) · Prefetch (exec history) · Registry (SYSTEM/SOFTWARE/SAM/NTUSER) · Event Logs (4624/4104) · LNK (file access even if deleted).  
**Velociraptor:** agent-server, push **VQL** queries (endpoints as SQL tables), near-instant fleet hunting, built-in dashboard. KAPE=deep single host; Velociraptor=live fleet.  
**Network (silent witness): NetFlow**=metadata "phone bill", cheap, 12+ mo, C2 patterns. **PCAP**=full packets "tape recording", expensive, days. Endpoints lie, network harder to fool.  
**TLS 1.3** hides handshake ⇒ pivot to endpoint visibility (netstat from RAM).  
**Cloud no-touch:** snapshot → clone to isolated forensic VPC → attach to clean VM. Zero downtime/observer effect. S3 Object Lock/Immutable Blob; CloudTrail = chain of custody.

**Anti-forensics:** **BYOVD** (signed vulnerable driver → kernel → kill EDR) · EDR blinding (direct syscalls). ⇒ cross-ref with network witness; tamper-proof agents.

**Lateral movement (Win):** WMI (5858/5861) · RDP logon type 10 (4624) · PS Remoting (Invoke-Command) · SMB C\$/Admin\$.

**Exfil:** Cloud HTTPS 70% · DNS tunnel 15% · ICM-P/SMTP 15%. Look for beaconing + spikes.

**SIEM** (detect, 30–90d) vs **Forensic data lake** (WORM, 1–2 yr, NIS2/DORA).

**Observer effect:** 128GB over 1Gbps ≈17 min; image is a "smear"; may BSOD host.

#### 15. Labs: Autopsy & Volatility

**Autopsy** = GUI front-end to **The Sleuth Kit**; disk-image analysis, recover deleted files, timelines, artifact exam. For post-incident disk: attacker tools, persistence, user-activity reconstruction. Needs a forensic test image.

**Volatility3** lab: `python3 vol.py -f dump.raw windows.pslist`; structured output `-r json|csv` → ELK/S-plunk.

#### Quick Numbers / Likely Gotchas

- NIS2: **24h / 72h / 1 month** ; fine 2% / €10M.
- GDPR breach: **72h** ; fines 2%/€10M (low), 4%/€20M (high). Enforced 25-May-2018.
- ISO cert valid **3 years** , annual surveillance.
- CSF: **6** functions (Govern new 2024), 4 tiers.
- SOC2 Type II: **3–12 months** of operation.
- Volatility magic: **4D5A=MZ**.
- Order of volatility: Reg/Cache > RAM > Net > Disk.
- Acquisition speed: **DMA < Net < SW** .
- Risk treatment: Avoid/Transfer/Mitigate/Accept.
- Win Event IDs: 4624 logon, 4688 process, 4104 PowerShell, 5858/5861 WMI.